

##CRISCC - Risk Response and Reporting Effectively

###Objectives:

At the end of this episode, I will be able to understand:

1. It's important that processes, logs, and audit books are commonly placed into the control framework
2. Monitoring and reporting controls is in the risk monitoring phase, but the capability must be planned as part of design
3. Risk practitioners work with stakeholders to setup the IS control monitoring
4. IS control monitoring is all about making sure that IT security requirements are met
5. Remember that the purpose of a control is to mitigate a risk
6. Steps for Monitoring Controls
 - Identify and confirm risk control owners
 - Engage with stakeholders and communicate the risk and IS requirements
 - Align and maintain the IS monitoring approach with IT staff
 - Establish IS processes and procedures
 - Determine Life-Cycle management and change control processes
7. Control Assessment Types:
 - SELF ASSESSMENT – Controls are most easily assessed by those who regularly interact with them as part of their job functions. Self-assessment is included in methodologies like NIST, COBIT, and COSO.
 - IS AUDIT – Audit teams provide independent and objective review of the effectiveness and appropriateness of the control environment
 - VULNERABILITY ASSESSMENT – We've talked about this earlier in our course. It's a methodical review of security to ensure that there are no predictable and unaddressed attack vectors. Risk Practitioners that participate need to have the technical know-how and non-technical knowledge to make this work. They also need to be careful of relying too heavily on automated tools, particularly when looking at the vulnerability of IT systems. Automated tools are best when used for the "We know about these vulnerabilities" vs. the new attacks.

Additional resources used during the episode can be obtained using the download link on the overview episode.

External Resources:

During this episode, you can reference the following external resources for supplementary tools and information:

<http://www.isaca.org>